

a one-page checklist from The Farah Stack

Before your agent goes live

Ten checks I run before an AI agent touches real users, real data or real money. Print it, tick it, keep it next to the deploy button.

- 1 Egress allowlist, not hope**
Deny by default. The agent reaches only the hosts it needs, and you can list them.

- 2 A budget cap per run**
Tokens, tool calls and wall-clock time, each with a hard stop that actually stops it.

- 3 A kill switch you've actually pulled**
Tested in staging this month, not just "configured". Someone besides you knows where it is.

- 4 A human who gets paged**
A named person and a short runbook for when it goes sideways at 2am.

- 5 Least-privilege, short-lived credentials**
Scoped to the task. "Admin, just for now" is admin forever.

- 6 Tools written down**
Which tools it may call, with which arguments. Anything else is refused, not improvised.

- 7 Untrusted input stays data**
Web pages, emails and tool output never become instructions. Try a prompt-injection test on purpose.

- 8 A human approves anything irreversible**
Send, delete, pay, merge, publish: the agent proposes, a person confirms.

- 9 Logs you can replay**
Every prompt, tool call and result under one run id, so "what did it do?" has an answer.

- 10 Evals before and after every change**
A fixed test set that runs in CI. A new model or prompt ships only if it still passes.

what works: boundaries the model can't argue with.

My agent harness

Every agent run gets its own throwaway copy of the repo and ends at a draft pull request, never a merge. If it makes a mess, I delete a folder and my real checkout never knows.

1

Fresh copy per run

A new git worktree and branch for each run: `git worktree add ../agent-run-42 -b agent/run-42`

2

The agent works only in there

No access to my main checkout, no production secrets, short-lived scoped credentials (page 1, check 5).

3

Build and test

It runs the build and the tests inside the copy. Failures go back to the agent, not to me.

4

Self-review on its own diff

A structured pass: correctness, tests, error handling, security. It writes down what it checked.

5

Push the branch, open a DRAFT pull request

`gh pr create --draft`, with what it changed, what it tested and what it's unsure about.

6

STOP. A human reads it.

The agent's token can't merge or release. Merging and releasing are separate decisions, made by a person.

7

Clean up

`git worktree remove ../agent-run-42`. Nothing left behind, nothing to untangle.

THE RULES I DON'T BEND

- Green checks are not approval. A diff that passed the agent's own tests is a very confident suggestion.
- Tests written in the same session by the same agent mostly prove it agrees with itself. Keep a test set it didn't write.
- One run, one task, one branch. Small diffs get read; huge ones get skimmed.
- If I can't tell what it did from the PR description and the logs, it didn't finish.

the stop matters more than the copy.